TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Microsoft 365 token-replay campaign compromised 97 accounts at 79 organizations

From **Cybersecurity Briefing - 2026-10-27** · 2026-10-22 to 2026-10-27 · Briefing generated 2026-10-27

REPORT ID	VERSION	HANDLING
LIT-CTI-20261027-01	1.1 · 2026-10-27 10:42 EDT	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-10-22	No update
CVES	**ANALYST**	
None	Nick Sturgeon	

THREAT CAMPAIGN (IDENTITY / BUSINESS EMAIL COMPROMISE) **MEDIUM**

EXPLOITED IN THE WILD (CAMPAIGN OBSERVED 2026-07-14 TO 2026-09-22; NO LATER ACTIVITY REPORTED)

OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

Huntress published research on 2026-10-22 describing a roughly ten-week campaign, from 2026-07-14 to 2026-09-22, in which an unidentified operator stole authenticated Microsoft 365 sessions and replayed them to take over business mailboxes [S1]. The tokens came mainly from adversary-in-the-middle (AiTM) phishing relays that sat between victims and the real Microsoft sign-in page, so victims completed MFA themselves and the relay kept the resulting session. Device-code phishing and social engineering were also used [S1]. Huntress calls the bulk reuse of these stolen tokens "token spraying." It responded to related incidents at 79 organizations and counted at least 497 successful sign-ins and more than 200,000 failed attempts from the campaign's address range [S1] [S2] [S5]. The briefing headline's figure of 97 compromised accounts could not be confirmed. Huntress and every secondary outlet reviewed report organizations and sign-ins, not accounts, and the Hacker News article that reportedly carried the 97 figure could not be located [S7].

Most replay traffic came from six rotating addresses in 193.26.115.0/24, rented from the Hamburg hosting provider 1337 Services GmbH (AS210558). Huntress and the press stress that this does not mean the provider took part [S1] [S6]. The operator ran two toolsets. One sent scripted OAuth2 token requests with a 'node' or bare 'Mozilla/5.0' user agent against Microsoft Graph, Exchange Online, SharePoint and the Device Registration Service. The other replayed sessions in a normal Chrome or Edge browser against OfficeHome and Exchange [S1]. After getting in, the operator registered at least 48 rogue Entra devices

named 'DESKTOP-' plus eight hex characters. In 19 organizations it wiped the user's MFA methods and registered its own authenticator within three hours. It also created short-named inbox rules that hid or deleted mail, including rules aimed at payroll and banking messages and at one external CPA [S1] [S2] [S3]. Inbox rules were created from consumer VPNs and other hosting providers, not from the main replay range, so blocking the /24 alone is not enough [S1] [S3].

The risk to any single organization is moderate, but the persistence it leaves behind is serious. A password reset does not remove attacker-registered devices or authenticators, and access tokens stay valid until they expire (Huntress notes about 90 minutes) unless sessions are revoked [S1] [S4]. Conditional Access blocked the operator in only four organizations during the September burst, while about 29 others were entered, which points to policy gaps such as app or client-type exclusions [S1] [S5]. Still unknown: who the operator is, which phishing kit or service was used, the AiTM lure domains (Huntress did not publish them), the total number of accounts, and how much data was taken [S1] [S6].

Defenders should search Entra sign-in logs for the published IPs, client IDs and user agents. They should also audit Entra devices, MFA method changes and inbox rules for the patterns described. For any confirmed hit, revoke sessions, reset the password, and remove rogue devices, authenticators and rules together [S1]. Longer term, move to phishing-resistant MFA, require MFA or block access for all users, all resources and all client app types with no exclusions, block device-code flow where it is not needed, and pilot Entra Token Protection for supported native apps [S1] [S8] [S9].

Key judgments

VERY LIKELY · MODERATE CONFIDENCE

AiTM token theft and replay against Microsoft 365 tenants of small and mid-size businesses will very likely continue over the next three months. Now that 193.26.115.0/24 has been published, the operator will likely move to new rented hosting, so static IP blocks will lose value quickly. [S1] [S2] [S6]

LIKELY · HIGH CONFIDENCE

Affected organizations that only reset passwords, without revoking sessions and removing rogue devices, attacker-added authenticators and hidden inbox rules, will likely stay accessible to the operator and exposed to follow-on business email compromise such as payroll diversion. [S1] [S3] [S4]

LIKELY · MODERATE CONFIDENCE

The true number of victim organizations is likely higher than 79, because Huntress could only see tenants it monitors and the replay range was used against a much larger number of failed targets. [S1] [S6]

UNLIKELY · MODERATE CONFIDENCE

Tenants that enforce MFA for all users, all resources and all client app types, and that block device-code flow, are unlikely to be fully compromised by this tradecraft. Phishing-resistant MFA would be needed to stop the AiTM capture step itself. [S1] [S8] [S9]

INDICATORS OF COMPROMISE

All indicators come from the Huntress write-up of 2026-10-22 [S1], partly repeated by GBHackers and Help Net Security [S2] [S3]. They cover activity from 2026-07-14 to 2026-09-22 and are now one to three months old. The IPs are rented hosting and VPN addresses that will churn, so treat them as retro-hunt leads rather than blocklist entries. Microsoft client and resource IDs are legitimate and only meaningful when combined with hosting-origin sign-ins.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`193.26.115.0/24`	Primary token-replay network block rented from 1337 Services GmbH (AS210558, Hamburg). Six main replay hosts sit in this /24. Huntress stresses the provider's involvement is not established.	REPORTED	2026-07-14	[S1] [S2] [S6]
other	`AS210558 (1337 Services GmbH)`	ASN hosting the replay infrastructure. Huntress notes a few other addresses from this provider sat outside the /24.	REPORTED	2026-07-14	[S1] [S3]
ipv4	`193[.]26[.]115[.]221`	Build A scripted token replay and rogue Entra device join host, Phase 1. First Huntress detection on a rogue DESKTOP- device; last activity 2026-08-03.	REPORTED	2026-07-14	[S1] [S3]
ipv4	`193[.]26[.]115[.]199`	Build B browser session replay host, Phase 1. Replayed the 2026-07-21 hijacked session about 12 minutes after relay capture.	REPORTED	2026-07-21	[S1] [S3]
ipv4	`193[.]26[.]115[.]16`	Build A token replay host linked to device-code phishing, Phase 2 (from about 2026-08-17).	REPORTED		[S1] [S3]
ipv4	`193[.]26[.]115[.]21`	Build A token replay host using a bare 'Mozilla/5.0' user agent and touching SharePoint Online, Phase 2.	REPORTED		[S1] [S3]
ipv4	`193[.]26[.]115[.]72`	Build A automated 'node' replay host, Phase 3 burst (2026-09-11 to 2026-09-15). Huntress reports 303 successful sign-ins across 29 organizations and 1,052 Conditional Access blocks at four organizations.	REPORTED	2026-09-11	[S1] [S5]
ipv4	`193[.]26[.]115[.]210`	Build B session replay host paired with an IPv6 AiTM relay, Phase 4 (2026-09-02 to 2026-09-22).	REPORTED		[S1]
ipv4	`124[.]198[.]132[.]33`	Continued a hijacked session during Phase 1.	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`45[.]83[.]31[.]44`	Failed replay of a stolen session (August 2026).	REPORTED		[S1]
ipv4	`192[.]159[.]99[.]172`	Failed replay of a stolen session (August 2026).	REPORTED		[S1]
ipv4	`185[.]238[.]2[.]195`	AiTM relay address the victim passed through at the MFA prompt in the 2026-07-21 session capture.	REPORTED	2026-07-21	[S1] [S3]
ipv6	`2400[:]8d60[:]2[:][:]1[:]841d[:]5dd`	AiTM relay hosted at Evoxt Sdn. Bhd., Phase 4.	REPORTED	2026-09-02	[S1]
ipv4	`167[.]148[.]41[.]96`	Interserver address that created payroll-hiding inbox rules, Phase 3.	REPORTED		[S1]
user-agent	node	Build A scripted OAuth2 token replay. A bare 'node' user agent on Entra sign-ins is unusual for real users.	REPORTED		[S1] [S3]
user-agent	`Mozilla/5.0`	Bare user agent with no platform details, seen with Build A on 193.26.115.21.	REPORTED		[S1] [S3]
other	`d3590ed6-52b3-4102-aeff-aad2292ab01c`	Client app ID for Microsoft Office (legitimate first-party app) used by Build A token requests. Only suspicious when combined with hosting-origin IPs or a node user agent.	REPORTED		[S1]
other	`29d9ed98-a469-4536-ade2-f981bc1d605e`	Client app ID for Microsoft Authentication Broker (legitimate) used by Build A, including for device registration.	REPORTED		[S1]
other	`4765445b-32c6-49b0-83e6-1d93765276ca`	Client app ID for OfficeHome (legitimate) used by Build B browser replay.	REPORTED		[S1]
other	`00000003-0000-0000-c000-000000000000`	Resource ID for Microsoft Graph targeted by Build A (legitimate resource).	REPORTED		[S1]
other	`00000002-0000-0ff1-ce00-000000000000`	Resource ID for Office 365 Exchange Online targeted by Builds A and B (legitimate resource).	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`00000003-0000-0ff1-ce00-000000000000`	Resource ID for SharePoint Online, accessed from 193.26.115.21 (legitimate resource).	REPORTED		[S1]
other	`01cb2876-7ebd-4aa4-9cc9-d28bd4d359a9`	Resource ID for Device Registration Service targeted by Build A to register rogue devices (legitimate resource).	REPORTED		[S1]
http-request	`Entra sign-in request type OAuth2:Token`	Token exchange from hosting infrastructure (Build A). Huntress recommends hunting for it with the Office or Authentication Broker client.	REPORTED		[S1]
http-request	`Entra sign-in request types Login:reprocess and OAuth2:Authorize`	Browser session replay (Build B) using the OfficeHome client.	REPORTED		[S1]
http-request	`Entra sign-in request type Cmsi:Cmsi`	Device-code and broker sign-ins seen in Phase 2.	REPORTED		[S1]
other	`AADSTS53003 (BlockedByConditionalAccess)`	Huntress says this block happens after authentication succeeds, so it indicates a valid stolen credential or token even though access was denied.	REPORTED		[S1]
other	`AADSTS50133 (SsoArtifactRevoked)`	Replay attempt with an already-revoked session (for example 2026-09-03 in Phase 4).	REPORTED	2026-09-03	[S1]
other	`DESKTOP-54521F46`	Rogue Entra device name registered by the operator.	REPORTED		[S1]
other	`DESKTOP-BAF88EF4`	Rogue Entra device name registered by the operator.	REPORTED		[S1]
other	`DESKTOP-CA85907C`	Rogue Entra device name registered by the operator.	REPORTED		[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`^(DESKTOP-|Device-|Work Pc)[0-9A-F]{8}$`	Regex built from the reported naming pattern ('DESKTOP-', 'Device-' or 'Work Pc' plus eight uppercase hex characters, unlike the Windows default of seven alphanumerics). Huntress warns the pattern is not unique to this campaign, so confirm before deleting. The exact separator for 'Work Pc' was not stated.	DERIVED		[S1] [S4]
other	`iPhone 13`	Label of the attacker-registered Microsoft Authenticator device added after MFA methods were wiped (2026-07-21 example at 18:08:50 UTC). Common legitimate label, so correlate with timing and sign-in source.	REPORTED	2026-07-21	[S1] [S2] [S3]
other	`apns2-d8a3fedb1a3cd1287ca47c6851a49e6052ab6116b43666e674765ca892d798ce`	Device token of the attacker-registered 'iPhone 13' authenticator.	REPORTED	2026-07-21	[S1]
other	`Inbox rule name: .`	Marks all mail as read and deletes it.	REPORTED		[S1] [S2]
other	`Inbox rule name: sss`	Marks all mail as read and deletes it.	REPORTED		[S1] [S2]
other	`Inbox rule name: ss`	Moves mail from a business partner's domain to RSS Feeds and marks it read.	REPORTED		[S1]
other	`Inbox rule name: iT`	Moves all mail to Conversation History and marks it read.	REPORTED		[S1] [S2]
other	`Inbox rule name: ,.`	Moves all mail to Conversation History and marks it read.	REPORTED		[S1]
other	`Inbox rule name: ........`	Moves all mail to RSS Subscriptions and marks it read.	REPORTED		[S1]
other	`Inbox rule name: s`	Hides messages containing payroll, direct deposit, bank or bonus terms.	REPORTED		[S1] [S5]
other	`Inbox rule name: d`	Moves all mail from one external CPA's address to Conversation History and marks it read, hiding replies to a payroll-themed lure.	REPORTED		[S1]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The operator phished users into AiTM relay pages, device-code prompts or social-engineered sign-ins. Each victim completed real Microsoft MFA, and the relay captured the authenticated session or tokens. The stolen sessions were then replayed at scale from rented hosting in 193.26.115.0/24. One toolset (Build A) was a scripted node client that requested OAuth2 tokens for Microsoft Office or the Authentication Broker against Graph, Exchange, SharePoint and the Device Registration Service. The other (Build B) replayed sessions in a Chrome or Edge browser against OfficeHome and Exchange. Over the four phases, the gap between capture and replay shrank from about 12 minutes to about 4 [S1]. To keep access after the token expired, the operator registered rogue Entra devices, wiped the user's MFA methods and enrolled its own authenticator. It then used separate VPN or VDI egress to create short-named inbox rules that hid payroll, banking and partner correspondence ahead of business email compromise, such as a payroll-themed email sent to an external CPA. In at least one mailbox it also sent spam [S1] [S2].

Threat actor

Unattributed token-spraying operator (Huntress, July-September 2026)

Attribution confidence: Low · **Motivation:** Financial (business email compromise, payroll diversion); assessed from observed payroll and banking rule targeting · **Suspected origin:** Unknown

Huntress names no actor or phishing kit. Infrastructure was rented from 1337 Services GmbH (AS210558), and the provider's involvement is explicitly not alleged. Huntress cites earlier Krebs on Security reporting about the provider's founder only as background. Egress for mailbox actions included ExpressVPN, NordVPN, CrownCloud, DataWagon, GLOBALTELEHOST, LeaseWeb, Dynu and Interserver [S1] [S6].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T1566.002 Phishing: Spearphishing Link	Lures led victims to AiTM fake sign-in pages or device-code prompts. Huntress did not publish the lure domains. [S1] [S6]	Email and URL telemetry for links to newly registered sign-in lookalikes. Sign-ins whose MFA prompt originated from hosting IPs.
Credential Access	T1557 Adversary-in-the-Middle	AiTM relays (for example 185.238.2.195 and an Evoxt IPv6 host) proxied the real Microsoft login and captured the post-MFA session. [S1] [S3]	Interactive sign-ins where the IP that completed MFA belongs to a hosting provider, followed within minutes by the same session from a different hosting IP.

Tactic	Technique	Procedure observed	Detection opportunity
Defense Evasion	T1550.001 Use Alternate Authentication Material: Application Access Token	Stolen tokens and sessions were replayed from 193.26.115.0/24 using OAuth2:Token (node user agent) or Login:reprocess and OAuth2:Authorize in a browser. [S1]	SigninLogs and AADNonInteractiveUserSignInLogs from hosting ASNs with node or bare Mozilla/5.0 user agents and the Office or Authentication Broker app IDs.
Persistence	T1098.005 Account Manipulation: Device Registration	At least 48 rogue Entra devices were registered through the Device Registration Service with names like DESKTOP- plus eight hex characters. [S1] [S2]	AuditLogs 'Register device' or 'Add device' events from hosting IPs. Device names matching the reported regex.
Persistence	T1556.006 Modify Authentication Process: Multi-Factor Authentication	In 19 organizations, existing MFA methods were deleted through security-info registration and a new authenticator (for example 'iPhone 13') was registered within three hours. [S1] [S4]	AuditLogs showing user security info deleted and then registered within a short window, especially after a hosting-origin sign-in.
Defense Evasion	T1564.008 Hide Artifacts: Email Hiding Rules	Inbox rules with 1-8 character or punctuation names deleted mail, marked it read, or moved it to RSS Feeds, RSS Subscriptions or Conversation History. Some rules were keyed on payroll and banking terms or on a CPA's address. [S1] [S2] [S5]	New-InboxRule and Set-InboxRule events with short names or moves to RSS or Conversation History folders.
Command and Control	T1090.003 Proxy: Multi-hop Proxy	Mailbox actions came from consumer VPNs and rented VDI tunnels. The final takeover went through an RDP VDI tunnel that changed the session's OS from macOS to Windows. [S1]	Mid-session changes in IP, ASN or device OS for the same session ID.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

Entra sign-ins from reported replay range or scripted token clients `KQL`

```
let replay_ips = dynamic(["193.26.115.0/24"]);
let extra_ips =
dynamic(["124.198.132.33","45.83.31.44","192.159.99.172","185.238.2.195","167.148.41.96","2400:8d60:2::
1:841d:5dd"]);
union isfuzzy=true SigninLogs, AADNonInteractiveUserSignInLogs
| where TimeGenerated > ago(120d)
| where ipv4_is_in_any_range(IPAddress, replay_ips) or IPAddress in (extra_ips)
   or (UserAgent in ("node", "Mozilla/5.0") and AppId in ("d3590ed6-52b3-4102-aeff-
aad2292ab01c","29d9ed98-a469-4536-ade2-f981bc1d605e"))
| project TimeGenerated, UserPrincipalName, IPAddress, AutonomousSystemNumber, AppDisplayName, AppId,
ResourceDisplayName, UserAgent, ResultType, ConditionalAccessStatus, SessionId
| order by TimeGenerated asc
```

Retro-hunt over the 2026-07-14 to 2026-09-22 window and later. Treat ResultType 0 and 53003 as evidence of a valid token or credential. Pivot on SessionId to find related sign-ins from other IPs.

Rogue device registration with campaign-style names `KQL`

```
AuditLogs
| where TimeGenerated > ago(120d)
| where OperationName in ("Add device", "Register device")
| mv-expand tr = TargetResources
| extend DeviceName = tostring(tr.displayName)
| where DeviceName matches regex @"^(DESKTOP-|Device-|Work Pc)[0-9A-F]{8}$"
| extend InitiatedBy = tostring(InitiatedBy.user.userPrincipalName), IP =
tostring(InitiatedBy.user.ipAddress)
| project TimeGenerated, OperationName, DeviceName, InitiatedBy, IP
```

The name pattern can occur legitimately. Confirm against the sign-in source (hosting ASN) and user before deleting a device. The 'Work Pc' separator is assumed.

MFA method deleted then re-registered within three hours `KQL`

```
let deleted = AuditLogs
| where TimeGenerated > ago(120d)
| where OperationName has "deleted security info" or OperationName has "Delete authentication method"
| extend User = tostring(TargetResources[0].userPrincipalName)
| project DelTime = TimeGenerated, User;
let added = AuditLogs
| where TimeGenerated > ago(120d)
| where OperationName has "registered security info" or OperationName has "Register authentication
method"
| extend User = tostring(TargetResources[0].userPrincipalName)
| project AddTime = TimeGenerated, User, AddDetail = tostring(AdditionalDetails);
deleted
| join kind=inner added on User
| where AddTime between (DelTime .. DelTime + 3h)
| project User, DelTime, AddTime, AddDetail
```

Operation names vary by tenant and log version. Validate them against your own AuditLogs first. Correlate with hosting-origin sign-ins in the preceding hours.

Suspicious short-named or folder-hiding inbox rules `KQL`

```
OfficeActivity
| where TimeGenerated > ago(120d)
| where Operation in ("New-InboxRule", "Set-InboxRule", "UpdateInboxRules")
| extend P = tostring(Parameters)
| extend RuleName = extract(@'"Name","Value":"([^"]*)"', 1, P)
| where strlen(RuleName) <= 3 or RuleName matches regex @"^[\W_]+$"
   or P has_any ("RSS Feeds", "RSS Subscriptions", "Conversation History")
   or P has_any ("payroll", "direct deposit", "bank", "bonus")
| project TimeGenerated, UserId, ClientIP, Operation, RuleName, P
```

Rules created through the Outlook REST API may appear as UpdateInboxRules or in CloudAppEvents rather than as New-InboxRule. Extend the query accordingly.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Microsoft 365 / Microsoft Entra ID tenants	Tenants without phishing-resistant MFA, or with Conditional Access gaps (app or client-type exclusions, device-code flow allowed)	N/A (configuration and identity hygiene, not a software flaw)	None	N/A	N/A	No	N/A

Immediate (0–24 hours)

- Retro-hunt Entra sign-in logs (interactive and non-interactive) from 2026-07-14 onward for 193.26.115.0/24 and the other reported IPs, node or bare Mozilla/5.0 user agents, and AADSTS53003 results from hosting ASNs. `SOC` [S1]
- For any confirmed account, revoke all sessions and refresh tokens and reset the password. In the same change, remove rogue Entra devices, unrecognized authenticators and malicious inbox rules. A password reset alone is not enough. `SOC` [S1] [S4]
- Audit Entra devices named DESKTOP-, Device- or Work Pc plus eight hex characters, MFA methods cleared and re-registered within minutes, and inbox rules with short or punctuation names or moves to RSS or Conversation History folders. `SOC` [S1] [S2]
- Warn payroll and finance contacts at affected clients to verify any payroll or direct-deposit change requests out of band, since the operator targeted payroll and an external CPA. `LEADERSHIP` [S1] [S5]

Short term (1–7 days)

- Fix Conditional Access so it requires MFA (or blocks) for all users, all resources and all client app types, with only audited break-glass exclusions. Rank tenant response by valid-credential signals, not by failed-attempt volume. `IT OPS` [S1]
- Create a Conditional Access authentication-flows policy that blocks device-code flow. Start in report-only, then enforce, and allow it only for documented and restricted service accounts. `IT OPS` [S1] [S9]
- Disable user consent to enterprise applications and review recently granted enterprise apps for tenant-wide access. `IT OPS` [S1]
- Deploy the detection queries in this report as scheduled analytics across managed tenants, and alert on device registration or MFA changes that follow hosting-origin sign-ins. `SOC` [S1]

Long term

- Move users, starting with admins, finance and executives, to phishing-resistant MFA (FIDO2 passkeys or Windows Hello for Business) so AiTM relays cannot capture a usable session. `LEADERSHIP` [S1] [S8]

- Pilot Entra Token Protection (Conditional Access session control) for Exchange Online, SharePoint and Teams on supported, managed Windows and Apple devices. Run it in report-only mode first, and note that browser support is limited. `IT OPS` [S8]
- Require compliant or managed devices for M365 access, and restrict who may register or join devices to Entra. `IT OPS` [S1] [S8]

Workarounds & compensating controls

- Use named locations or risk-based Conditional Access to block or challenge sign-ins from hosting and VPN ASNs where business use allows. Do not rely on blocking the single /24, since the operator rotated hosts and used other providers for mailbox actions. `IT OPS` [S1] [S3]
- Turn on mailbox audit and transport rules that alert on new inbox rules moving mail to RSS or Conversation History folders. `IT OPS` [S1]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] Huntress: M365 Token Spray and Replay Campaign Compromises Business Email Accounts
Published 2026-10-22 · `A2` Completely reliable, probably true
Primary source. Original research with full IOCs, ATT&CK mapping and guidance. Contains one internal inconsistency in Phase 3 counts (303/29 vs 232/28).

[S2] Help Net Security: Microsoft 365 accounts compromised at 79 organizations, no passwords needed
Published 2026-10-23 · `B2` Usually reliable, probably true
Secondary coverage of S1. Notes that Entra ID Protection flagged several addresses independently.

[S3] GBHackers: Microsoft 365 Token Replay Attacks Let Hackers Access Business Emails Without Passwords
Published 2026-10-27 · `C2` Fairly reliable, probably true
Secondary coverage that repeats a subset of the S1 IOCs.

[S4] ID Tech: Huntress Finds Stolen Microsoft 365 Sessions Used Across 79 Organizations
Published 2026-10-23 · `C2` Fairly reliable, probably true
Secondary coverage of S1.

[S5] SecurityOnline: Microsoft 365 token replay attack (Huntress)
Published 2026-10-22 · `C2` Fairly reliable, probably true
Secondary coverage of S1. No account count.

[S6] The Arabian Post: Token replay campaign breaches Microsoft 365 accounts at 79 organisations
Published 2026-10-24 · `C2` Fairly reliable, probably true
Secondary coverage. Notes that 79 reflects only Huntress response scope and that the operator is unidentified.

[S7] The Hacker News: Front page listing (2026-10-26/27)
Published 2026-10-26 · `B6` Usually reliable, truth cannot be judged
Briefing's original source. When fetched on 2026-10-27, the front page no longer showed the article, and the '97 accounts' figure could not be verified anywhere.

[S8] Microsoft Learn: How Token Protection Enhances Conditional Access Policies
Published 2026-08-14 · `A1` Completely reliable, confirmed by other sources
Vendor documentation for the token-binding mitigation.

[S9] Microsoft Learn: Block authentication flows with Conditional Access policy
Published 2026-03-24 · `A1` Completely reliable, confirmed by other sources
Vendor guidance for blocking device-code flow.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-07-14	First Huntress detection: sign-in from 193.26.115.221 with a rogue DESKTOP- device (Phase 1 begins).	[S1]
2026-07-21	Example hijack: relay capture via 185.238.2.195 at 17:18 UTC, replay from 193.26.115.199 about 12 minutes later, 'iPhone 13' authenticator registered at 18:08.	[S1] [S3]
2026-08-03	Last activity from 193.26.115.221.	[S1]
2026-08-17	Phase 2 begins after a two-week gap. Device-code phishing and MFA wiping are added.	[S1]
2026-09-02	Phase 4 IPv6 AiTM relay (Evoxt) first appears. A replay on 2026-09-03 fails with AADSTS50133.	[S1]
2026-09-11	Phase 3 burst from 193.26.115.72 begins. Huntress sends incident reports to 22 customers within two hours.	[S1] [S6]

Date	Event	Source
2026-09-22	Final observed session takeover, with relay-to-replay gap down to about four minutes.	[S1]
2026-10-22	Huntress publishes its research.	[S1] [S5]
2026-10-23	Secondary coverage begins (Help Net Security, ID Tech), followed by The Arabian Post on 2026-10-24 and GBHackers on 2026-10-27.	[S2] [S4] [S6] [S3]

Relevance to Indianapolis, Indiana & managed clients

This campaign hit small and mid-size businesses that rely on Microsoft 365 for email. That describes most of Lucidia IT's managed clients and many Indiana organizations: local government offices, school districts, clinics and healthcare practices, manufacturers and professional-services firms. The payroll-diversion and CPA-targeting behavior matters most for Indiana employers with outsourced accounting or payroll. For healthcare clients, a compromised mailbox could also become a HIPAA breach-assessment issue. Because Huntress saw victims only among its own customers, Indiana organizations should not assume they were spared. Lucidia should run the retro-hunt queries across every managed tenant for the July-September window and check each client's Conditional Access for app or client-type exclusions and allowed device-code flow. It should also prioritize phishing-resistant MFA for finance, payroll and executive users. Clients on Microsoft 365 Business Premium already have Conditional Access and can pilot Token Protection on managed devices.

Intelligence gaps

- The briefing's figure of 97 compromised accounts could not be confirmed. Huntress and all secondary sources report 79 organizations and 497 successful sign-ins, with no account count. Treat 97 as unverified.
- The operator's identity, phishing kit or PhaaS platform, and AiTM lure domains were not published, including the Phase 2 lookalike business-partner domain.
- The total victim population beyond Huntress customers is unknown, as is the extent of data access or financial loss.
- Phase 3 figures are inconsistent within the Huntress post (303 sign-ins across 29 organizations vs 232 across 28).
- There is no Microsoft statement or advisory on this campaign. Watch for Microsoft Threat Intelligence or CISA reporting and for new infrastructure after the published range is abandoned.

Other notes

- Huntress separately reported a June 12-26, 2026 password-spray campaign from LSHIY LLC IPv6 space (about 81 million attempts, 78 accounts at 64 organizations) that used the ROPC flow. It is a distinct campaign with different infrastructure and should not be confused with this one. Its figures come from search results only; the Huntress support article returned HTTP 403 and was not cited.
- Huntress stresses that 1337 Services GmbH appears only as the hosting provider of the replay servers, and its involvement is not alleged.
- Huntress says Microsoft flagged individual replay addresses but not the /24. Blocking the /24 would have covered the six main replay hosts but not the VPN and hosting egress used for inbox-rule creation.

LIT-CTI-20261027-01 v1.1 · Generated 2026-10-27 10:42 EDT from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.